LaunchGuard Readiness Report

TARGET URL	https://mineazy-shop.onrender.com/
SCAN ID	–
GENERATED	2026-06-02 12:46 UTC

Launch Verdict

Blocked

3 confirmed launch blockers must be fixed before shipping.

Next action: Fix the launch blockers, rotate any exposed credentials where needed, then run a verification scan.

Scan profile: Controlled Security Audit. Security-focused scan using configured passive and active checks.

Top launch actions

Blocked: Terraform vars (secrets) exposed

Blocked: Weak TLS support reported by sslscan: SSLv2

Blocked: Weak TLS support reported by sslscan: SSLv3

18/100

LaunchGuard Score

Critical Risk

Site Screenshots

This report was automatically generated. Review with qualified security professionals.
False positives may occur. Manual testing is recommended for critical systems.



Desktop (1440px)



Mobile (390px)

Executive Summary

48 security issues were detected across this scan. These findings should be reviewed and remediated promptly.

HTTP Header Issues	7
OWASP ZAP Alerts	14
Sensitive File Exposure	2

OWASP Top 10 2021 – Coverage Summary

The table below shows which OWASP Top 10 2021 categories were evaluated in this scan and whether findings were detected.

Category	Status	Findings	Scanners Run
A01:2021 – Broken Access Control	Covered	0	redirect, takeover
A02:2021 – Cryptographic Failures	Issues Found	11	ssl, headers, secrets
A03:2021 – Injection	Issues Found	15	sqli, xss, zap
A04:2021 – Insecure Design	Covered	0	malicious

Category	Status	Findings	Scanners Run
A05:2021 – Security Misconfiguration	Issues Found	14	headers, exposure, wordpress, dns
A06:2021 – Vulnerable and Outdated Components	Issues Found	2	tech, malware_analysis
A07:2021 – Identification and Authentication Failures	Issues Found	2	auth
A08:2021 – Software and Data Integrity Failures	Issues Found	9	integrity
A09:2021 – Security Logging and Monitoring Failures	Issues Found	8	logging_monitor
A10:2021 – Server-Side Request Forgery	Covered	0	ssrf

Coverage is based on the scan profile used. 'Not Tested' categories were not included in this scan.

Detailed Findings

✓ SQL Injection Analysis

No issues detected

✓ No SQL injection vulnerabilities were detected.

✓ SSL/TLS Certificate

Valid certificate

Issuer	Google Trust Services
Subject	onrender.com
Expires	Aug 24 22:01:50 2026 GMT
Protocol	TLSv1.3

✗ HTTP Header Security

7 issues found

Missing content-security-policy — High

content-security-policy was not present in the response.

Missing x-frame-options — Medium

x-frame-options was not present in the response.

Missing referrer-policy — Low

referrer-policy was not present in the response.

Missing permissions-policy — Low

permissions-policy was not present in the response.

This report was automatically generated. Review with qualified security professionals.
False positives may occur. Manual testing is recommended for critical systems.

Missing cross-origin-opener-policy — Medium

cross-origin-opener-policy was not present in the response.

Missing cross-origin-resource-policy — Low

cross-origin-resource-policy was not present in the response.

Information disclosure via server — Low

server: cloudflare

- Add a Content-Security-Policy header to defend against XSS.
- Set X-Frame-Options to DENY or SAMEORIGIN to block clickjacking.
- Set Referrer-Policy to control how much referrer info is sent.
- Add a Permissions-Policy header to restrict browser feature access.
- Add Cross-Origin-Opener-Policy: same-origin to prevent Spectre-style cross-origin attacks.
- Add Cross-Origin-Resource-Policy: same-origin to prevent cross-site resource loading.
- Suppress or genericise the Server header to avoid version disclosure.

— WordPress Security

Not a WordPress site

No WordPress installation detected on this target.

✗ OWASP ZAP Analysis

14 alerts

Missing Anti-clickjacking Header — Medium

The response does not protect against 'ClickJacking' attacks. It should include either Content-Security-Policy with 'fra

Re-examine Cache-control Directives — Informational

public, max-age=0, s-maxage=300

Content Security Policy (CSP) Header Not Set — Medium

Content Security Policy (CSP) is an added layer of security that helps to detect and mitigate certain types of attacks,

Modern Web Application — Informational

<script defer="defer" src="/static/js/main.1cb7a991.js"></script>

Retrieved from Cache — Informational

Age: 32

Re-examine Cache-control Directives — Informational

public, max-age=0, s-maxage=300

Retrieved from Cache — Informational

Age: 33

Re-examine Cache-control Directives — Informational

public, max-age=0, s-maxage=300

Retrieved from Cache — Informational

Age: 33

Missing Anti-clickjacking Header — Medium

The response does not protect against 'ClickJacking' attacks. It should include either Content-Security-Policy with 'fra

Re-examine Cache-control Directives — Informational

public, max-age=0, s-maxage=300

Content Security Policy (CSP) Header Not Set — Medium

Content Security Policy (CSP) is an added layer of security that helps to detect and mitigate certain types of attacks,

Modern Web Application — Informational

<script defer="defer" src="/static/js/main.1cb7a991.js"></script>

Retrieved from Cache — Informational

Age: 33

✓ Nikto Web Server Scan

No findings

✓ **Nikto found no additional web server findings.**

✓ Malicious Content Analysis

No threats detected

✓ **No malicious indicators detected.**

Threat Score: 0/10

✓ Cross-Site Scripting (XSS)

No reflected XSS detected

✓ **No reflected XSS vectors detected in tested parameters.**

Content-Security-Policy header missing — Medium

No CSP detected — add one as a defence-in-depth measure

✓ Technology Fingerprinting

No actionable technology issues

Css Frameworks	Bootstrap
Cdn	Cloudflare
Analytics	Google Analytics

No WAF detected — Info

wafw00f did not identify a web application firewall.

Detected: Bootstrap — Info

Identified in the tech stack.

- Older Bootstrap versions may have XSS vulnerabilities.

✗ Sensitive File Exposure

2 paths exposed

robots.txt exposed (check Disallow paths)

SEVERITY	Low
URL	`https://mineazy-shop.onrender.com/robots.txt`
SIZE	67 bytes
PREVIEW	`# https://www.robotstxt.org/robotstxt.html User-agent: * Disallow:`

Terraform vars (secrets) exposed

SEVERITY	Critical
URL	`https://mineazy-shop.onrender.com/terraform.tfvars`
SIZE	709 bytes

- Never expose CI/CD configs, Dockerfiles, or cloud credentials via HTTP.
- Block access to sensitive files via Nginx `deny all` or Apache `Require all denied` directives.

✓ Hardcoded Secrets & API Keys

No hardcoded secrets detected

✓ **No hardcoded API keys or secrets detected in page source or JavaScript files.**

This report was automatically generated. Review with qualified security professionals.
False positives may occur. Manual testing is recommended for critical systems.

✓ Downloaded Artifact Malware Analysis

No malware indicators detected

✓ No malware indicators were detected in same-origin downloadable artifacts.

✗ DNS Security (SPF / DMARC / DKIM)

5 issues

No SPF record — High

No SPF TXT record found for mineazy-shop.onrender.com. Attackers can send spoofed email appearing to come from this doma

No DMARC record — High

No DMARC TXT record found at _dmarc.mineazy-shop.onrender.com. Without DMARC, SPF and DKIM results are not enforced.

No DKIM record found (common selectors checked) — Medium

None of the common DKIM selectors (default, google, mail, k1, selector1, selector2, dkim, email, smtp) returned a DKIM1

DNSSEC not enabled — Low

No DS or DNSKEY records found for mineazy-shop.onrender.com. DNSSEC prevents DNS cache poisoning attacks.

No CAA record — Low

No CAA record for mineazy-shop.onrender.com. Any CA can issue certificates for this domain.

- Add an SPF record: v=spf1 include:<your-mail-provider> -all
- Add a DMARC record: v=DMARC1; p=quarantine; rua=mailto:dmarc-reports@yourdomain.com
- Configure DKIM signing on your mail server and publish the public key as a TXT record at <selector>._domainkey.<domain>.
- Enable DNSSEC for your domain — configure it at your DNS registrar and publish DS records.
- Add CAA records to restrict which certificate authorities may issue certificates for your domain. Example: 0 issue "letsencrypt.org"

✓ Open Redirect

Pass

✓ No open redirect vulnerabilities detected.

✓ Subdomain Takeover

Pass

✓ No dangling CNAMEs or unclaimed service fingerprints found across 47 subdomains.

✓ Server-Side Request Forgery (SSRF)

Pass

✓ No SSRF indicators detected in tested parameters.

✗ Security Logging & Monitoring

8 issues found

Finding — low

Neither /.well-known/security.txt nor /security.txt returned a valid response.

OWASP: A09:2021 – Security Logging and Monitoring Failures

Finding — high

GET /error.log returned HTTP 200 (709 bytes).

OWASP: A09:2021 – Security Logging and Monitoring Failures

Finding — high

GET /access.log returned HTTP 200 (709 bytes).

OWASP: A09:2021 – Security Logging and Monitoring Failures

Finding — high

GET /debug.log returned HTTP 200 (709 bytes).

OWASP: A09:2021 – Security Logging and Monitoring Failures

Finding — high

GET /app.log returned HTTP 200 (709 bytes).

OWASP: A09:2021 – Security Logging and Monitoring Failures

Finding — high

GET /application.log returned HTTP 200 (709 bytes).

OWASP: A09:2021 – Security Logging and Monitoring Failures

Finding — high

GET /server.log returned HTTP 200 (709 bytes).

OWASP: A09:2021 – Security Logging and Monitoring Failures

Finding — low

No known monitoring SDK domains found in page scripts.

This report was automatically generated. Review with qualified security professionals.
False positives may occur. Manual testing is recommended for critical systems.

OWASP: A09:2021 – Security Logging and Monitoring Failures

- Add a security.txt contact file at /.well-known/security.txt.
- Ensure log files are not publicly accessible.
- Configure error handlers to show generic messages in production.
- Integrate an error monitoring SDK (e.g. Sentry) for real-time alerting.

✗ Authentication Controls

2 issues found

Finding — low

No MFA-related terms found in page content.

OWASP: A07:2021 – Identification and Authentication Failures

Finding — medium

HEAD https://mineazy-shop.onrender.com/login returned 200 with no rate-limit headers.

OWASP: A07:2021 – Identification and Authentication Failures

- Set HttpOnly, Secure, and SameSite=Lax on all session cookies.
- Implement rate limiting on authentication endpoints.
- Enable multi-factor authentication for user accounts.
- Add autocomplete attributes to password fields.

✗ Software & Data Integrity

9 issues found

Finding — medium

No Content-Security-Policy header found. Without CSP, browsers cannot enforce SRI for subresources.

OWASP: A08:2021 – Software and Data Integrity Failures

Finding — low

GET /.travis.yml returned HTTP 200 (709 bytes).

OWASP: A08:2021 – Software and Data Integrity Failures

Finding — low

GET /Jenkinsfile returned HTTP 200 (709 bytes).

OWASP: A08:2021 – Software and Data Integrity Failures

This report was automatically generated. Review with qualified security professionals.
False positives may occur. Manual testing is recommended for critical systems.

Finding	low
GET /.circleci/config.yml returned HTTP 200 (709 bytes).	
OWASP: A08:2021 – Software and Data Integrity Failures	
Finding	**low**
GET /circle.yml returned HTTP 200 (709 bytes).	
OWASP: A08:2021 – Software and Data Integrity Failures	
Finding	**low**
GET /package-lock.json returned HTTP 200 (709 bytes).	
OWASP: A08:2021 – Software and Data Integrity Failures	
Finding	**low**
GET /yarn.lock returned HTTP 200 (709 bytes).	
OWASP: A08:2021 – Software and Data Integrity Failures	
Finding	**low**
GET /Pipfile.lock returned HTTP 200 (709 bytes).	
OWASP: A08:2021 – Software and Data Integrity Failures	
Finding	**low**
GET /composer.lock returned HTTP 200 (709 bytes).	
OWASP: A08:2021 – Software and Data Integrity Failures	

- Add integrity= (SRI hash) and crossorigin= attributes to all external scripts and stylesheets.
- Implement a Content-Security-Policy header to enforce SRI.
- Block public access to CI/CD config files and dependency lockfiles.

Conclusion & Recommended Next Steps

1. HTTP Headers	Add missing security headers (CSP, HSTS, X-Frame-Options, etc.).
2. ZAP Alerts	Triage each alert and patch confirmed vulnerabilities.
3. File Exposure	Block sensitive paths in the web server and rotate any exposed credentials.
4. DNS Security	Configure SPF (-all), DMARC (p=quarantine or reject), DKIM signing, and CAA records.

This report was automatically generated. Review with qualified security professionals.
False positives may occur. Manual testing is recommended for critical systems.

Developer Best Practices

- Adopt secure-by-default output encoding and enforce a strict Content-Security-Policy across all templates and SPAs.
- Standardize security headers and cookie flags in a shared middleware layer so new vibecoded pages inherit safe defaults.
- Keep source, backup, env, and debug artifacts out of the web root, and validate deployment bundles before publish.
- Use authenticated code review and protected branches even for AI-generated code; fast generation increases the need for release guardrails.
- Add pre-production checks for secrets, dependency risk, headers, and exposed debug routes before every deployment.

Report Limitations

LaunchGuard performs automated security, UX, accessibility, SEO and reliability checks against the approved target and selected pages. A READY TO SHIP verdict means no configured launch-blocking issues were detected during this scan. It does not guarantee the application is free of vulnerabilities, accessible in every scenario, or protected against future failures. High-risk applications handling payments, personal data, or sensitive workflows should undergo additional manual security review.

This report was automatically generated. Review with qualified security professionals.
False positives may occur. Manual testing is recommended for critical systems.